

BattleOps: Week 3

Theme: Kubernetes Security, Platform Hardening & Real-World Incident Prevention

Objective: Apply Kubernetes security concepts in real production-like situations, debug misconfigurations, enforce policies, and secure workloads end-to-end.

FRIDAY: Supply Chain Security, Image Signing, Admission Control

ADVANCED CONCEPTS

- How attackers inject malicious images
- Real-world supply chain attacks (SolarWinds, Codecov)
- Image provenance & SLSA
- Using cosign to sign images
- Enforcing verification using admission controllers

KEY OUTCOMES

- You can sign & verify images
 - You can enforce policy: “Only signed images may run”
 - You understand how admission controllers protect clusters
-

WHAT TO PRACTICE

Lab 1: Sign an Image

Use cosign to sign a simple demo image.

Lab 2: Verify Trust

Run verification commands & interpret results.

Lab 3: Enforce “Signed Images Only”

Use Kyverno or OPA Gatekeeper:

- Reject unsigned images
- allow signed images

WHERE TO STUDY

- Sigstore / cosign docs
 - Kyverno policies repo
 - SLSA.dev introduction
- 

INFRATHRONE BATTLEOPS NOTES

- Your cluster is only as secure as the images you run.
- Signed images reduce supply chain attacks dramatically.
- Every enterprise is moving toward SLSA levels; learn it early.